

LAB-2

PEN TESTING WITH METASPLOITABLE

Requirements:

- Oracle Virtual Box Installed
- Kali Linux 2025
- Metasploitable VM

IN LAB-1, we already learned how to install Oracle virtual box and Kali Linux and Metasploitable.

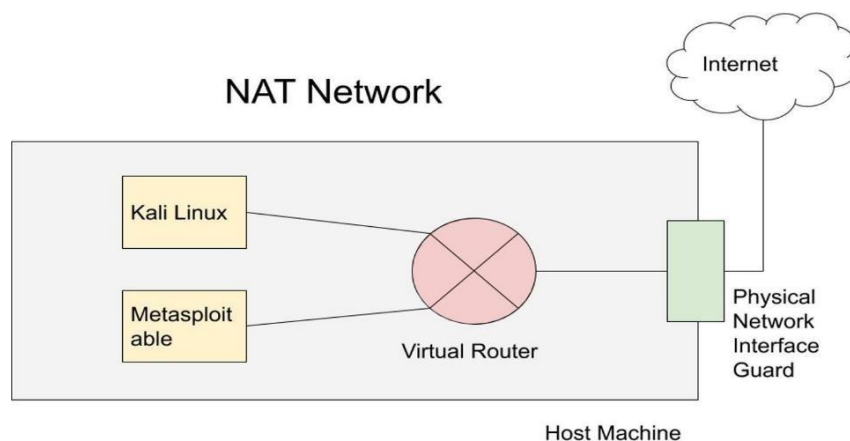
Today we will learn the following tasks:

1. Setting up a NAT network to connect Kali and Metasploitable so that both machines can communicate with each other and with machines outside the network as well (internet) securely.
2. Installation of Metasploitable
3. A walkthrough of Metasploitable VM – Pen testing

ACTIVITY0 – CHECK THE DEFAULT IP ADDRESS DISPLAYED INSIDE KALI LINUX AND METASPLOITABLE

Use the `ifconfig` command in the command prompts of the two virtual machines and check the `eth0` IP address.

ACTIVITY1: SETTING UP NAT NETWORK ON VIRTUAL BOX



In virtual box NAT network is a type of internal network that allows outbound connections. The Network Address Translation (NAT) service works in a similar way to a home router, grouping the systems using it into a network and preventing systems outside of this network from directly accessing systems inside it, but letting systems inside communicate with each other and with systems outside using TCP and UDP over IPv4 and IPv6.

ACTIVITY2: SETTING UP NAT NETWORK IN KALI NETWORK

ACTIVITY3: SETTING UP NAT NETWORK IN METASPLOITABLE

After the above three activities we have set up a NAT network for all virtual machines with Classless Inter-Domain Routing (CIDR) which is 10.0.2.0/24. IPV4 address is 32 bit long and it contains 4 octets. Each octet is of 8 bits. Therefore, all our virtual machines will get the first three octets the same because in CIDR notation /24 represents that we have reserved 24 bits as network address and only 8 bits for host addresses. So, if virtual machines are connected on this network their first three octets must be the same (i.e. 10.0.2.X), here X represents the host address, but X can vary from one virtual machine to another. If you didn't understand much of what was mentioned about IP don't worry! It's not critical to understand the complete details but if you would like to have a quick introduction or a refresher on IP addresses, the CIDR notation or Network Address Translation you can watch <https://www.youtube.com/watch?v=z07HTSzzp3o> or similar YouTube tutorials on these topics.

ACTIVITY4: SCANNING THE METASPLOITABLE VM FOR IDENTIFYING VULNERABILITIES

Since we know the IP address of the Metasploitable VM we can now use Kali Linux for the purpose of auditing our target system using **nmap** to identify vulnerabilities within our target system. We now scan the target system using the **nmap** command. <https://www.kali.org/tools/nmap/>

ACTIVITY5: HACKING UNREAL IRCD 3.2.8.1 ON METASPLOITABLE

For this attack we will use Metasploit attack framework from Kali. Remember that Kali is our attacker machine and metasploitable virtual machine is our target / victim machine. To perform attack using Kali Linux we will have to perform following steps:

1. Initiate and run the Metasploit attack framework pre-installed on Kali virtual machine using PostgreSQL service.
2. Now search for the IRCD exploit that we have identified above in Activity 4.
3. After finding exploit related to IRCD we will use that exploit to perform an attack using Metasploit attack framework in Kali Linux.
4. After this we need to see payload and options available for our preferred payload.
5. Now set IP address of remote HOSTS and local HOST RHOSTS is a target Machine and local host is the attacker machine.
6. Now execute the exploit using Metasploit attack framework.

Finally, you successfully executed the exploit and now you can see remote session is open. This will access Metasploitable -2 Virtual machine and have root access. Hence you can execute any terminal commands to execute. Now, let's try a few commands given below and analysis the output:

```
$whoami  
$uname -a
```

Activity 6: Metasploitable VM pen testing activity:

Activity 6.A: Scan the target system for vulnerabilities using the nmap command(<https://www.kali.org/tools/nmap/>)

Activity 6.B: Exploiting VSFTPD v2.3.4 with Metasploit attack framework

For this attack we will use Metasploit attack framework from Kali. Remember that Kali is our attacker machine and metasploitable virtual machine is our target / victim machine. Metasploit attack framework is pre-installed on Kali virtual machine, we need to initiate the database of the attack framework. Database is developed in PostgreSQL, so first we have to start the PostgreSQL service and then we initiate / create default database of attack framework.

1. Start Metasploit attack framework using PostgreSQL database
2. Search for the VSFTPD v2.3.4 exploit in Metasploit attack framework
3. Select the VSFTPD v2.3.4 backdoor exploit using Metasploit attack framework
4. Set the attack settings and run the exploit.
5. Now we have successfully executed the attack and **have root (full) access**.
6. Execute some commands to verify.

Backdoor

Vulnerabilities provide holes through which hackers break into our system. These vulnerabilities are open doors that hackers leverage to gain access to systems. The metasploitable server has an FTP vulnerability that can be exploited by the “back door”. A back door is an intentional flaw that was added to a system by an attacker that allows the attacker to gain access.

Activity 6.C: Create a file in Metasploitable VM and delete that file using the backdoor opened from Kali Linux.

1. Check the current directory of Metasploitable VM
2. Create a new file in Metasploitable machine using touch command.
3. View the file from the backdoor opened from Kali Linux
4. Delete the file using rm command from the backdoor opened in Kali Li
5. Verify file delete from Metasploitable machine

Activity 7: Exploit VSFTPD port with Telnet service

In this activity, we are going to look at a vulnerability that was added by a malicious developer to an open-source UNIX FTP server called vsftpd. The backdoor allowed the attacker to gain access to the terminal on the vulnerable machine. The attack was activated when the attacker logged into the FTP using a username ending in :) and an invalid password. Once the attack was activated it opened a reverse shell on port 6200.

Reverse Shell: A reverse shell is a malicious program that connects to an attacker's machine, allowing the attacker to execute terminal commands on the compromised machine.

Teletype Network Protocol (Telnet): Telnet, is a protocol that provides a command line interface for communication with a remote device or server. Telnet is commonly used by terminal emulation programs that allow you to log into a remote host. A legitimate user who knows their username and password can log into a remote host using a telnet service.

Step 1: Connect to the FTP server using telnet. Open the terminal on your Kali Linux machine and telnet metasploitable using VM IP address and 21 port.

Step 2: If you can open a new terminal and do nmap on port 6200, you will see that it is open.

Step 3: Now that you have activated the back door you can now login to get access to the terminal (Get Shell). By connecting to the "backdoor" that is running on 6200. Connect the backdoor using Netcat. Now use the Linux command to list all of the files on the machine.

Step 4: Create and remove file named "IamRoot" in Metasploitable machine's folder using the shell opened from Kali Linux. Also verify if it is created and removed using Linux command.